RESUMEN EJECUTIVO · COMITÉ EJECUTIVO · TLP:RED

Acceso no autorizado a facturas de clientes

Incidente de seguridad en el servicio de consulta de facturas del portal

Resumen del incidente

Referencia	IR-2021-001	**Fecha del reporte**	14 de octubre de 2026
Líder técnico del caso	Yeyson Javier Cañón Forero	**Clasificación**	TLP:RED
Qué ocurrió	Consulta automatizada y no autorizada de facturas de clientes usando cuatro cuentas válidas del portal mercadolibre.com	**Servicio afectado**	Consulta de facturas del portal (Argentina, Brasil, Colombia y México)
Periodo del ataque	1 de octubre al 31 de diciembre de 2020	**Detección**	12 de enero de 2021, alerta del firewall de aplicaciones y monitoreo interno
Tiempo hasta detectar	103 días	**Tiempo hasta contener**	1 hora 54 minutos desde la detección
Facturas potencialmente expuestas	Entre 10.181 y 27.746, según cómo numere cada país sus facturas	**Severidad**	Crítica
Estado	Contenido. Confirmación de afectados y corrección del servicio en curso	**Riesgo actual**	Medio, hasta desplegar la corrección

EJEMPLO TÉCNICO · INFORMA

1. Qué ocurrió

Entre octubre y diciembre de 2020, un tercero utilizó cuatro cuentas válidas del portal web *mercadolibre.com* en el contexto */invoices/search* y herramientas automáticas para consultar facturas de clientes que, con alta probabilidad, no le pertenecían. El servicio verificaba que quien consultaba tuviera una sesión válida, pero no que la factura solicitada fuera suya, bastaba con cambiar el número de factura en la consulta para obtener la de otro cliente.

El incidente se detectó el 12 de enero de 2021 por una alerta del firewall de aplicaciones y el monitoreo interno, 103 días después de la primera actividad. La contención se aplicó en menos de dos horas desde la detección.

Qué sabemos y qué falta confirmar

Sabemos que las cuatro cuentas recibieron respuesta a miles de consultas de facturas, que más de 5.000 de ellas nunca habían sido consultadas por ningún cliente y que la actividad fue automatizada y planificada. Los registros analizados no indican a qué cliente pertenece cada factura, por lo que las cifras corresponden al máximo potencialmente expuesto. Además, si cada país numera sus facturas de forma independiente, un mismo número consultado en varios países corresponde a facturas distintas y la exposición ***sube de 10.181 a 27.746*** *facturas. Ambas preguntas se responden con la información del dueño del servicio, ya solicitada.*

2. Cronología simplificada

Fecha	Hecho
Octubre de 2020	El atacante prueba el servicio con herramientas automáticas sin obtener información
1 de noviembre de 2020	Obtiene la primera factura. Durante noviembre consulta unas 500 facturas por día
Diciembre de 2020	Triplica el ritmo, cerca de 1.500 consultas diarias con 94 % de éxito, y empieza a pedir facturas que ningún cliente había consultado
12 de enero de 2021	Detección. En menos de dos horas se bloquean las herramientas, las direcciones y las cuentas del atacante

3. Características del ataque

- Fue planificado y automatizado: tres fases de un mes con un volumen diario idéntico, las 24 horas del día.
- Se hizo con cuentas legítimas del portal, sin forzar contraseñas. El origen de esas cuentas, creadas por el atacante o robadas a clientes, se está investigando.

- Fue coordinado desde cinco direcciones de Internet que compartían las mismas cuentas, para repartir la carga y evitar bloqueos.
- Pasó inadvertido durante tres meses: el servicio nunca rechazó una consulta del atacante y ninguna regla de monitoreo lo detectó, aunque la actividad era visible desde el primer día.
- Una segunda actividad en diciembre, con credenciales posiblemente de pruebas y en horario laboral, parece ser de pruebas internas y se está validando antes de tomar medidas.

4. Impacto para el negocio

Ámbito	Impacto
Clientes	Entre 10.181 y 27.746 facturas potencialmente expuestas, que según el escenario contienen datos personales. El registro no incluye el contenido de las respuestas; los campos expuestos (por lo general nombre, identificación tributaria, dirección, productos y montos) deben confirmarse con el dueño del servicio. Por país, hasta 6.899 en Argentina, 6.959 en Brasil, 6.918 en Colombia y 6.970 en México
Fraude y reputación	Riesgo de fraude dirigido con datos reales de compra y de daño reputacional en cuatro mercados, mayor si los datos se publican o el incidente se conoce por terceros
Operación	Sin interrupción del servicio ni alteración de información: el ataque solo consultó datos
Económico	Orden de magnitud entre USD 1,6 y 4,4 millones según el número de clientes que se confirme, con base en un costo promedio de USD 160 por registro de cliente expuesto (IBM, 2025). No incluye sanciones; la cifra la valida el área financiera

5. Riesgo regulatorio y legal

Las facturas contienen datos personales y posiblemente financieros de titulares en cuatro jurisdicciones. Este análisis no constituye asesoría legal y debe validarlo el área jurídica de cada país, incluidas las obligaciones contractuales con aliados y medios de pago.

País	Norma y autoridad	Obligación y plazo	Sanción máxima de referencia	Riesgo
Brasil	LGPD · ANPD	Comunicar a la autoridad y a los titulares en 3 días hábiles si el riesgo es relevante	2 % de la facturación local, hasta R$ 50 millones por infracción	Alto
Colombia	Ley 1581 de 2012 · SIC	Reportar en el Registro Nacional de Bases de Datos en 15 días hábiles	2.000 salarios mínimos (unos COP 3.502 millones en 2026)	Alto
México	LFPDPPP (vigente desde marzo de 2025)	Informar al titular cuando la vulneración afecte de forma significativa sus derechos	A confirmar por el área jurídica	Medio alto
Argentina	Ley 25.326 · AAIP	Sin obligación general de notificar; la autoridad recomienda reportar	Sanción por falta de medidas de seguridad	Medio

Los plazos corren desde que la organización conoce el incidente; confirmar los afectados permite notificar con cifras ciertas y no con el máximo teórico.

6. Acciones de contención ejecutadas

Acción	Estado
Preservación de la evidencia con integridad verificable, válida ante el área jurídica o una autoridad	Ejecutada
Investigación de tres meses de registros: atacante, cronología, alcance e indicadores de compromiso	Ejecutada
Límite de velocidad y bloqueo de las herramientas automáticas usadas por el atacante	Ejecutada
Bloqueo de las cinco direcciones del atacante y desactivación de sus cuatro cuentas	Ejecutada
Monitoreo reforzado con alertas de consultas masivas	Ejecutada
Confirmación de clientes afectados y del esquema de numeración con el dueño del servicio	En curso
Corrección del servicio para que cada consulta verifique al dueño de la factura	En curso (Desarrollo)
Validación de la actividad con credenciales de prueba y retiro de esas credenciales de producción	En curso (AppSec y QA)
Evaluación jurídica y preparación de notificaciones a autoridades y clientes	En curso (Jurídica)

7. Lecciones aprendidas

- El servicio confiaba en cualquier cuenta válida, bastaba con haber iniciado sesión para consultar facturas de otros clientes, porque el servicio no verificaba a quién pertenecía cada una. Es un control básico, y a partir de ahora debe probarse cada vez que el servicio cambie.
- El ataque se pudo haber detenido el primer día, la actividad fue evidente desde el 1 de octubre, pero se detectó 103 días después. Los registros del portal no llegaban al centro de monitoreo, y el firewall de aplicaciones solo generaba alertas, sin bloquear.
- Sin registros completos no podemos medir el daño ya que los registros actuales no indican qué cliente consultó cada factura, así que hoy no podemos dar la cifra exacta de afectados con nuestra propia información; depende de la que entregue el dueño del servicio.

8. Plan de mejora continua

Acción de mejora	Beneficio para la organización	Plazo
Corregir la vulnerabilidad identificada	Elimina la causa del incidente	Inmediato
Evaluar si la misma condición existe en otros portales o aplicaciones con arquitectura similar	Evita que el ataque se repita por otro canal	3 meses
Priorizar una prueba de Red Team sobre el portal afectado	Confirma de forma independiente que la corrección y los controles funcionan	3 meses
Cambiar las reglas del firewall de aplicaciones de modo detección a modo bloqueo para ataques automatizados	Detiene ataques automatizados en minutos, sin intervención manual	30 días
Integrar los registros de la plataforma al SOC para tener una visión integral de las transacciones	Permite ver y correlacionar lo que ocurre en el portal	30 días
Diseñar reglas de monitoreo para detectar enumeración masiva y actividad automatizada de reconocimiento	Reduce el tiempo de detección de meses a horas	30 días
Implementar capacidades de inteligencia de amenazas y threat hunting sobre plataformas críticas	Anticipa ataques en lugar de esperar a que ocurran	6 meses
Fortalecer el monitoreo de fuentes externas donde se divulguen credenciales o información de clientes	Detecta fugas antes que los clientes, los medios o las autoridades	6 meses
Fortalecer el desarrollo seguro con Security Champions, Secure SDLC y remediación continua	Evita que fallas similares lleguen a producción	12 meses
Actualizar el análisis de riesgo de ciberseguridad del activo afectado	Alinea inversiones y controles con el riesgo real	3 meses
Profundizar la investigación con actividades forenses complementarias	Confirma el impacto y el origen de las cuentas usadas	30 días
Fortalecer el entendimiento de los servicios y procesos de negocio en los equipos de seguridad para alinear los controles al contexto operativo	Controles que protegen sin afectar la operación	6 meses

Decisiones que se solicitan al Comité

1. Instruir al dueño del servicio para entregar en 24 horas la relación factura-cliente y el esquema de numeración por país.
2. Priorizar la corrección del servicio sobre otros desarrollos.
3. Activar a Jurídica y Privacidad para preparar las notificaciones.
4. Aprobar el plan de mejora continua y sus responsables.

EJERCICIO · PRÁCTICA

Clasificación **TLP:RED**. No se debe compartir información designada como **TLP:RED** con ningún tercero fuera del ámbito donde fue expuesta originalmente.